

Hands-On-Learning: Map Privacy Controls Across ISO 27701 and NIST

Learning Objectives

By the end of this activity, learners will be able to:

- Identify relevant privacy controls from ISO 27701 and the NIST Privacy Framework for a specific business process.
 - Use a generative AI tool (Google Gemini) to accelerate the mapping of internal procedures to external standards.
 - Document control mappings and compliance notes in a structured format suitable for audit preparation.
-

Description

This lab simulates the detailed work of a privacy officer tasked with demonstrating compliance across multiple frameworks. Learners will use Google Gemini integrated with Google Sheets to map their organization's internal privacy procedures to the specific requirements of ISO 27701 and the NIST Privacy Framework. This exercise focuses on the critical skill of control tailoring and justification, demonstrating how to create auditable evidence of compliance for a privacy program.

Structure of the Activity

Title: Map Privacy Controls Across ISO 27701 and NIST

Tool used:

Google Sheets

Google Gemini (can be used in a separate window and results pasted into Sheets)

Scenario

You are a Privacy Officer at "Health-AI," a company that provides AI-driven diagnostic tools to hospitals. Your company handles sensitive patient data and must demonstrate compliance with both ISO 27701 (as a PII processor) and the NIST Privacy Framework to win new contracts. Your task is to create a control mapping document that connects your internal "Data Subject Access Request (DSAR)" procedure to specific clauses in both standards, preparing for an upcoming client audit.

Objective

To use Google Gemini and Sheets to match an internal privacy procedure to ISO 27701 and NIST Privacy Framework functions, generating a draft control mapping with compliance notes for audit preparation.



Instructions for learners

1 Preparation:

Open a new Google Sheet.

Create the following columns: Internal Procedure Step, ISO 27701 Control, NIST Privacy Framework Function, Compliance Notes/Evidence.

In the Internal Procedure Step column, add these steps for your DSAR process:

Verify the identity of the data subject.
Log the request in the tracking system.
Locate and retrieve the subject's data from production systems.
Deliver the data securely to the subject within 30 days.

2 AI-Powered Mapping:

Open Google Gemini.

Craft a prompt to get the control mappings. Example Prompt: "Act as a privacy compliance expert. For a Data Subject Access Request process, map the following step to the relevant controls from ISO/IEC 27701:2019 (for PII Processors) and the Functions in the NIST Privacy Framework v1.0. The step is: 'Verify the identity of the data subject.'"

Run the prompt for each of your four procedure steps.

Copy the relevant ISO 27701 control (e.g., 7.3.1) and NIST Privacy Framework function (e.g., PR.IP-1) from Gemini's output into the corresponding columns in your Google Sheet.

3 Documentation:

In the Compliance Notes/Evidence column, briefly describe how your company meets the control.

For "Verify the identity of the data subject," your note might be:
"Evidence: Copy of ID verification workflow from our support portal.
Link to internal procedure doc #4.2."

Complete this for at least two of the procedure steps.

Organize Information Following This Structure for Peer Review

Title Page: Project title, your name, date.

AI Prompt: Provide the final, refined prompt you used to get the control mappings from Gemini.

Control Mapping Screenshot: Submit a single, clear screenshot of your completed Google Sheet showing the mapped controls and compliance notes.

Justification: In one paragraph, explain why mapping controls to multiple frameworks (ISO and NIST) is valuable for a company like Health-AI.

Instructions for Documenting and Sharing the Project for Peer Review

Document the Project



Use word processing software to create your report. Insert the screenshot directly into your document. Ensure all sections of the project structure are completed. Proofread your report for clarity.

Share the Project



Save your report in PDF format. Upload your document to the “Peer Review” area in the course shell. Provide a brief description of your project in the submission post.



Peer Review

Review the projects submitted by your peers and provide constructive feedback on their work.

This activity gives learners a chance to apply the lesson by using AI to efficiently create a detailed, audit-ready artifact that bridges the gap between internal processes and external regulatory requirements.